Fondamenti sulla Sicurezza in SQL Server

DATA SATURDAYS

Innova community

Sponsors

CONSORZIO
UNIVERSITARIO
DI PORDENONE
MOLTIPLICATORE DI VALORE

altitudo

beanTech
IT moves your business

OVERNET.
upgrade your digital skills

[stesi]
Powered by Innovation

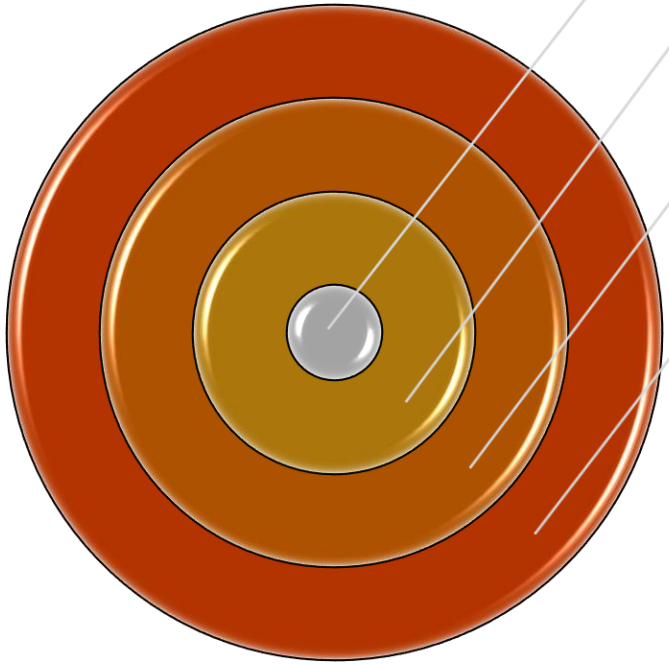
DATA
SATURDAYS

inn0va
community

About me

- Gianluca Hotz | @glhotz | ghotz@ugiss.org
- Consulente Indipendente
  - 30 anni con SQL Server (dalla versione 4.21 nel 1996)
  - «Database modeling & development, sizing & administration, modernization (upgrades & migrations), performance tuning, security»
- YNAP SQL Server DBA Team (part-time)
- «Community»
  - 25+ anni Microsoft MVP SQL Server/Data Platform (dal 1998)
  - «VMware Experts SQL Server»
  - Fondatore e presidente UGISS (ex «PASS Chapter»)

Security Layering



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Data Masking**
- **Row-Level Security**
- **Ledger Tables**

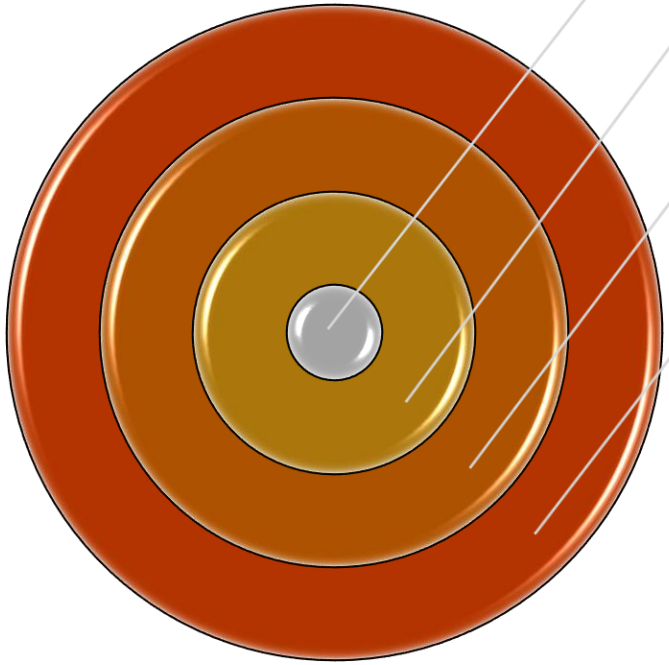
Access Control

- **Authentication**
- **Permissions**

Proactive monitoring

- **Auditing**
- **Vulnerability Assessment**

Access Control



Data Encryption

- Transport Layer Security (in transit)
- Transparent Data Encryption (at rest)
- Cell-Level Encryption (at rest)
- Always Encrypted (at rest and in transit)

Data Access

- Data Masking
- Row-Level Security
- Ledger Tables

Access Control

- Authentication
- Permissions

Proactive monitoring

- Auditing
- Vulnerability Assessment

Controllo degli accessi

- Connettività rete/Firewall (che device)
- Autenticazione (chi sono)
- Autorizzazioni (cosa posso fare)

- **Principio guida: minor privilegio!**

Traffico SQL Server e Firewall

- Traffico query/risultati TDS (Tabular Data Stream)
  - Porta di default TCP 1433 (assegnata da IANA)
  - DAC (Dedicated Admin Connection) su porta TCP 1434
  - Availability Group Listener best practice su porta di default TCP 1433
  - Altre porte dinamiche/statiche comunicate da SQL Browser
- SQL Browser
  - Porta UDP 1434
- Availability Groups (DB Mirroring)
  - Porta TCP 5022 per convenzione

Punti di autenticazione

- Server login
  - Controllo degli accessi e permessi a livello di istanza
- Database User
  - Controllo degli accessi e permessi a livello di singolo database
- Ambiti riconducibili a livelli server e/o database
  - SQL Server Replication, SQL Server Agent Jobs
- Impersonificazione e funzionalità specifiche
  - Database Mirroring, Availability Groups
  - «Extensibility Framework»
  - Identità per Linked Server, Polybase
  - «Bulk Insert» da «Azure Blob Storage»

Modalità di autenticazione

- Nativa SQL Server
  - Utente e hash password mantenuti in SQL Server
- Integrata con Active Directory
  - Utilizza protocollo NTLM o Kerberos
  - Supporto per Entra (Azure Active Directory)
- Best Practice
  - Autenticazione integrata con Kerberos
  - Database Containment (autenticazione a livello database)

SPN per autenticazione Kerberos

- Named instance
  - **MSSQLSvc/<FQDN>:[<port> | <instancename>]**
    - **MSSQLSvc** servizio che si sta registrando
    - **<FQDN>** nome di dominio completo del server
    - **<port>** numero della porta TCP
    - **<instancename>** nome dell'istanza di SQL Server
- Default instance
  - **MSSQLSvc/<FQDN>:<port> | MSSQLSvc/<FQDN>**
    - **MSSQLSvc** servizio che si sta registrando
    - **<FQDN>** nome di dominio completo del server
    - **<port>** numero della porta TCP

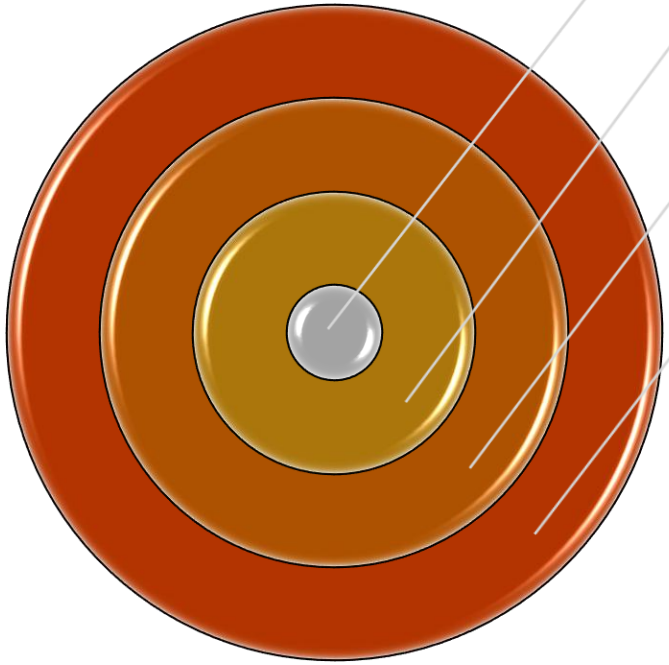
Registrazione SPN

- Permessi
  - «Validated Write servicePrincipalName» («advanced»)
    - «Read servicePrincipalName» e «Write servicePrincipalName»
- Automatica
  - Alla partenza del servizio sia con porta TCP che senza (per «named pipes»)
  - Account servizio o «Computer Object» deve avere i permessi
    - Utenza Windows specifica non li ha di default
    - «Managed Service Account (MSA) li ha di default
    - «Computer Object» li ha di default
      - «Local System», «Network Service», Virtual Account («Network Service»)
- Manuale
  - Comando **`setspn.exe`**
  - Cmdlet PowerShell modulo AD **`Set-AdUser`** oppure dbatools **`Set-DbaSPN`**

Autorizzazioni

- Permessi granulari
  - GRANT cosa può fare ON su che oggetto TO chi
  - Ereditarietà gerarchia di oggetti
  - Assegnazione (GRANT), negazione (DENY), revocare (REVOKE)
  - Row Level Security
- Ruoli a livello di server e database
  - Es. sysadmin, dbcreator, db_datareader, db_datawriter
  - Specifici per alcune funzionalità (database msdb)
- Principio guida: minor privilegio!
  - Possibile elevare temporaneamente
    - Impersonation
    - Stored Procedure (in generale moduli T-SQL firmati)

Data Encryption



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Data Masking**
- **Row-Level Security**
- **Ledger Tables**

Access Control

- **Authentication**
- **Permissions**

Proactive monitoring

- **Auditing**
- **Vulnerability Assessment**

Attore principale: crittografia, ma dove?

- Dati in transito
  - Autenticazione (sempre crittografata)
  - Spostamento dati
    - invio richieste (parametri)
    - caricamento in memoria
    - invio risposte (record set)
- Dati a riposo
  - File database (dati e log transazioni)
  - File di trace/audit

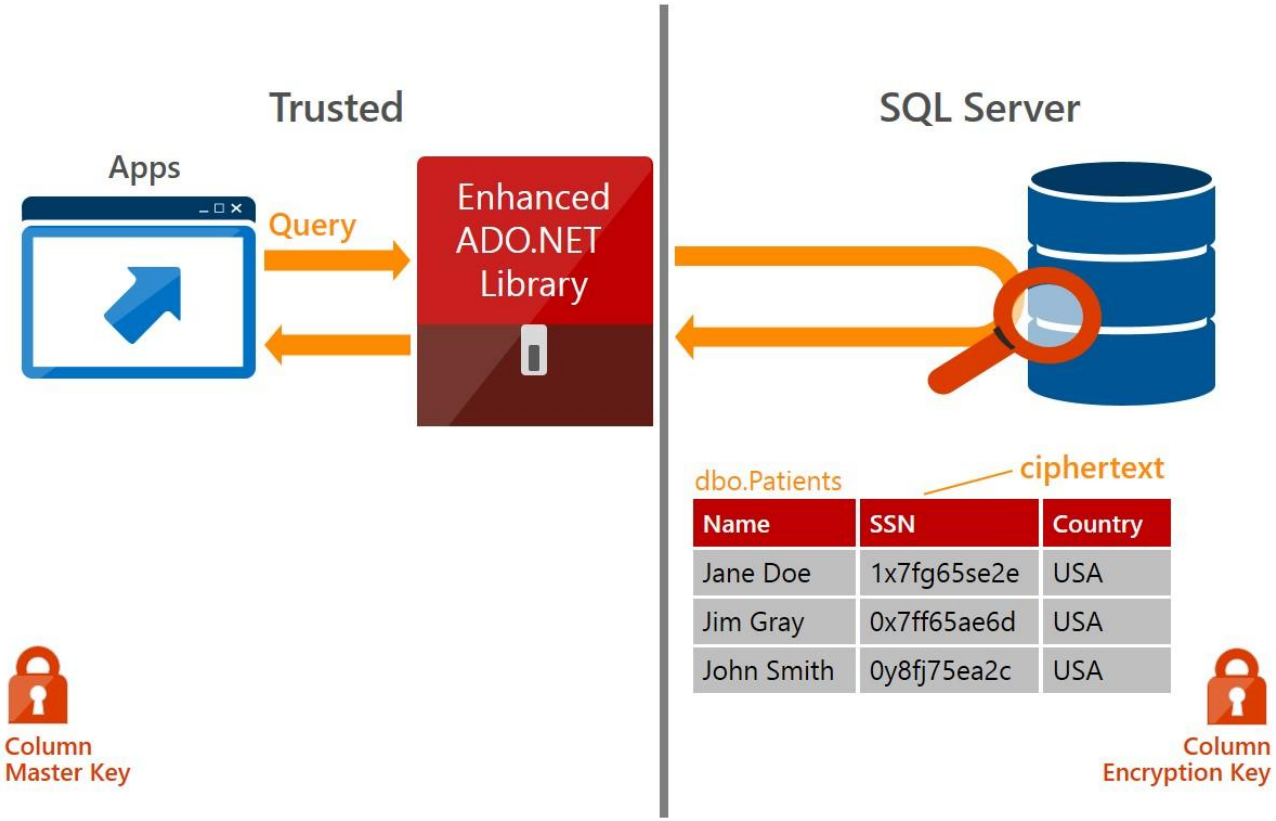
Crittografia comunicazioni

- Connessione crittografata
  - Installazione Certificato (server e client)
  - Possibile forzare utilizzo (server e client)
  - Autenticazione sempre crittografata (nel caso «self-signed»)
- Transport Layer Security (TLS) 1.2+
  - Windows Server 2008 R2
  - SQL Server 2008 SP4 (hotfix)
  - https://support.microsoft.com/en-us/help/3135244/tls-1.2-support-for-microsoft-sql-server
- Transport Layer Security (TLS) 1.3
  - SQL Server 2022 e TDS 8.0
  - Nuova opzione stringa di connessione per forzare TLS più stringente
    - **Encrypt=Strict** usa TDS 8 e **TrustServerCertificate** deve puntare a un certificato
    - **Encrypt=mandatory|true|yes** usa TDS 7.x e può ancora utilizzare **TrustServerCertificate=true**
  - https://learn.microsoft.com/sql/relational-databases/security/networking/tds-8-and-tls-1-3

Crittografia dati prima di SQL Server 2016

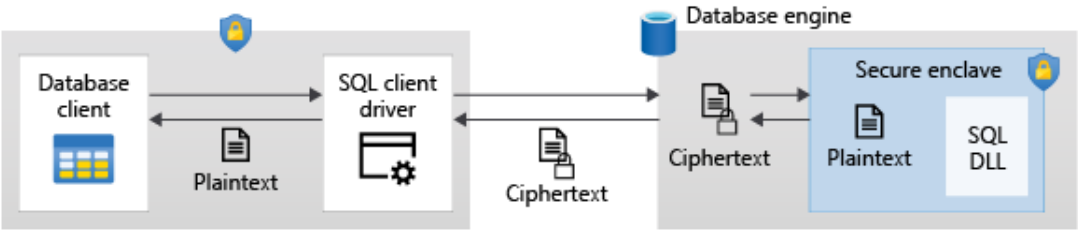
- Transparent Data Encryption (TDE)
  - File dati, log e backup
  - Dati decifrati quando caricati in memoria*
  - Completamente trasparente per le applicazioni
- Cell-Level Encryption (CLE)
  - Granularità a livello di Colonna
  - Protezione parziale in memoria
  - Non trasparente per le applicazioni
- Entrambi meccanismi crittografici Server-Side
  - TDE solo protezione dati a riposo (es. furto dischi o backup)
  - Utenti con privilegi elevati possono ottenere accesso ai dati

Panoramica Always Encrypted



«Always Encrypted» con «Secure Enclaves»

- Permette computazioni lato server su colonne crittografate
- «Secure Enclaves»
  - «Virtualization-based Security (VBS)»
  - AKA «Virtual Secure Mode(VSM) enclaves»
- Protezione «Enclave»
  - «plaintext» non possono essere divulgati all'esterno dell'enclave
  - «Column Master Keys» comunicate tramite canale sicuro dal driver lato client

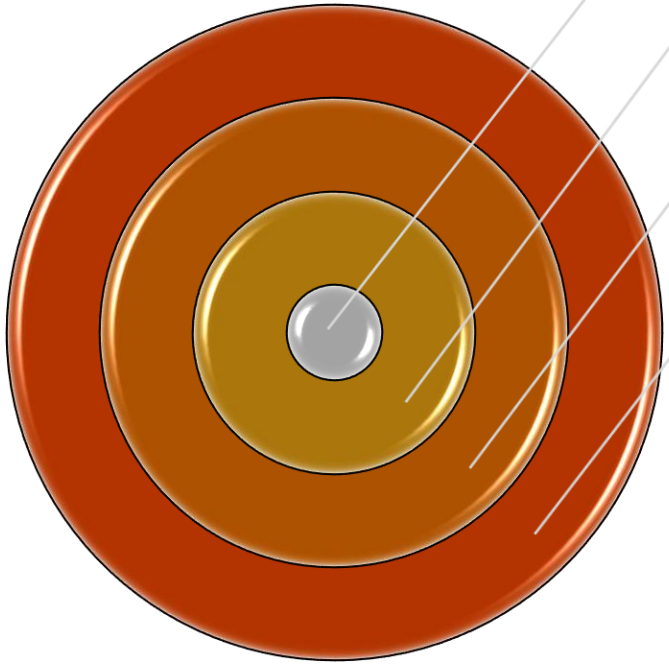


Operazioni con «Secure Enclaves»

- Miglioramenti SQL 2022
  - Thread multipli
  - Memorizzazione chiavi in cache
  - Più operazioni supportate
- Riferimento
  - https://learn.microsoft.com/sql/relational-databases/security/encryption/always-encrypted-enclaves

Operation/ Support	Azure SQL Database	SQL Server 2022	SQL Server 2019
Comparison operators	Yes	Yes	Yes
BETWEEN	Yes	Yes	Yes
IN	Yes	Yes	Yes
LIKE	Yes	Yes	Yes
DISTINCT	Yes	Yes	Yes
Joins	Yes	Yes	Only nested loops
ORDER BY	Yes	Yes	No
GROUP BY	Yes	Yes	No

Data Access



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Data Masking**
- **Row-Level Security**
- **Ledger Tables**

Access Control

- **Authentication**
- **Permissions**

Proactive monitoring

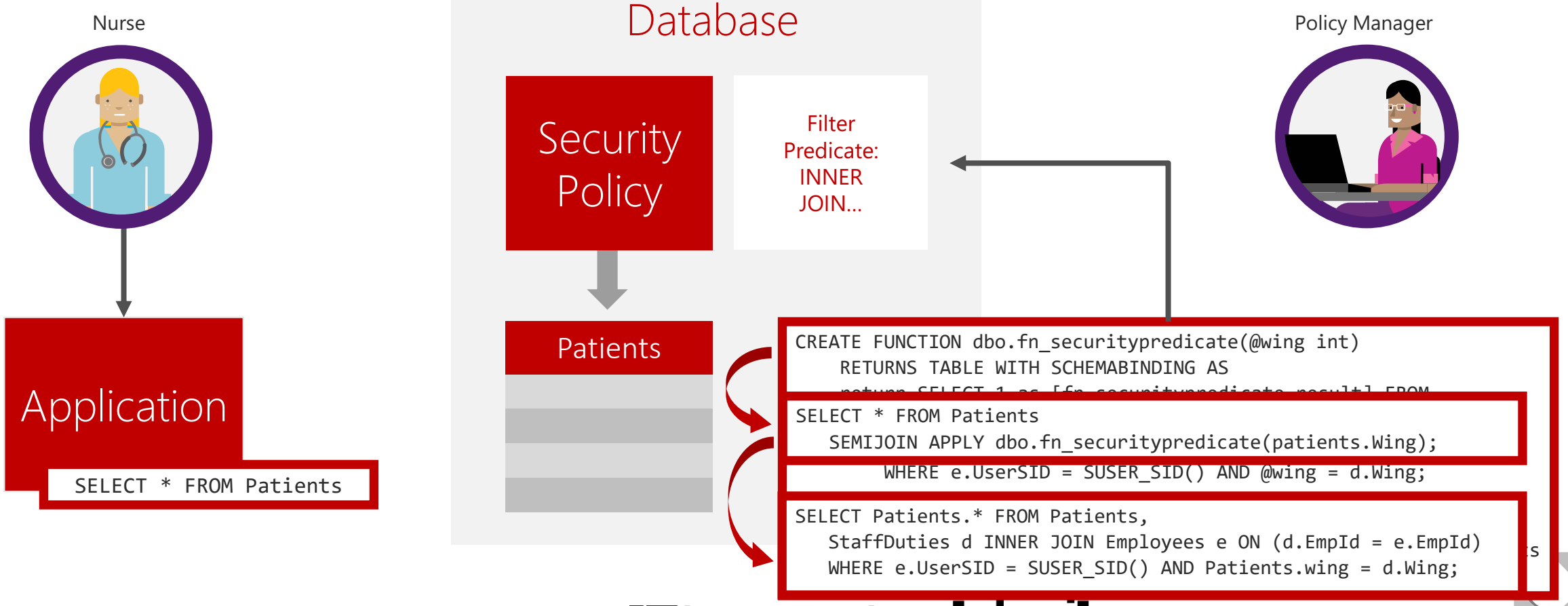
- **Auditing**
- **Vulnerability Assessment**

Panoramica Row Level Security

- Restringe l'accesso a un sottoinsieme di righe
- Basata su predicati di sicurezza
  - Definiti come «inline Table-Valued Functions»
  - «Filter predicate» limita righe a operazioni in lettura
    - SELECT, UPDATE e DELETE
  - «Block predicate» bloccano operazioni di scrittura
    - AFTER INSERT, AFTER/BEFORE UPDATE, BEFORE DELETE
- «Security Policy»
  - Applica i predicati di sicurezza alle tabelle

«Row-Level Security»

L'utente (Policy Manager) assegna una Security Policy che aggiunge il predicato T-SQL, vincolando il predicato alla tabelle dei pazienti.



Row-Level Security & Multi Tenancy

- Vincola accesso ai «tenant» quando «shard» condividono le stesse tabelle
- Assumendo esistenza colonna che identifica il «tenant»

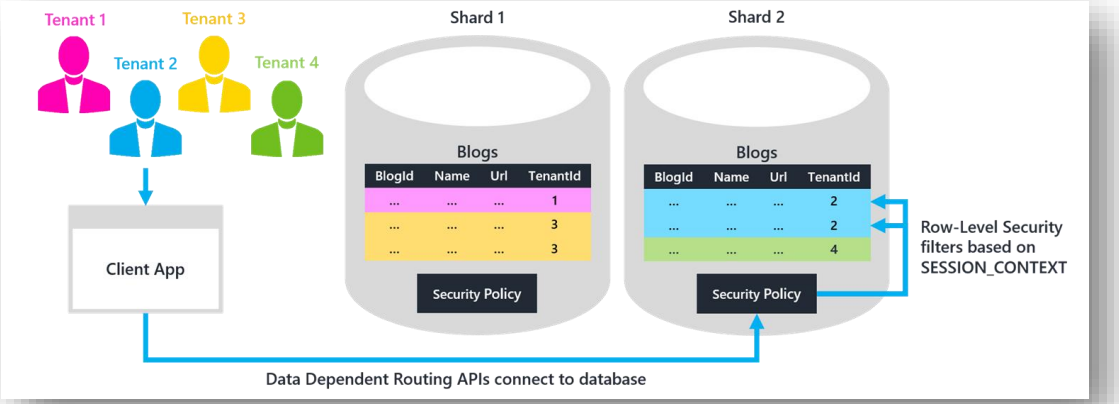
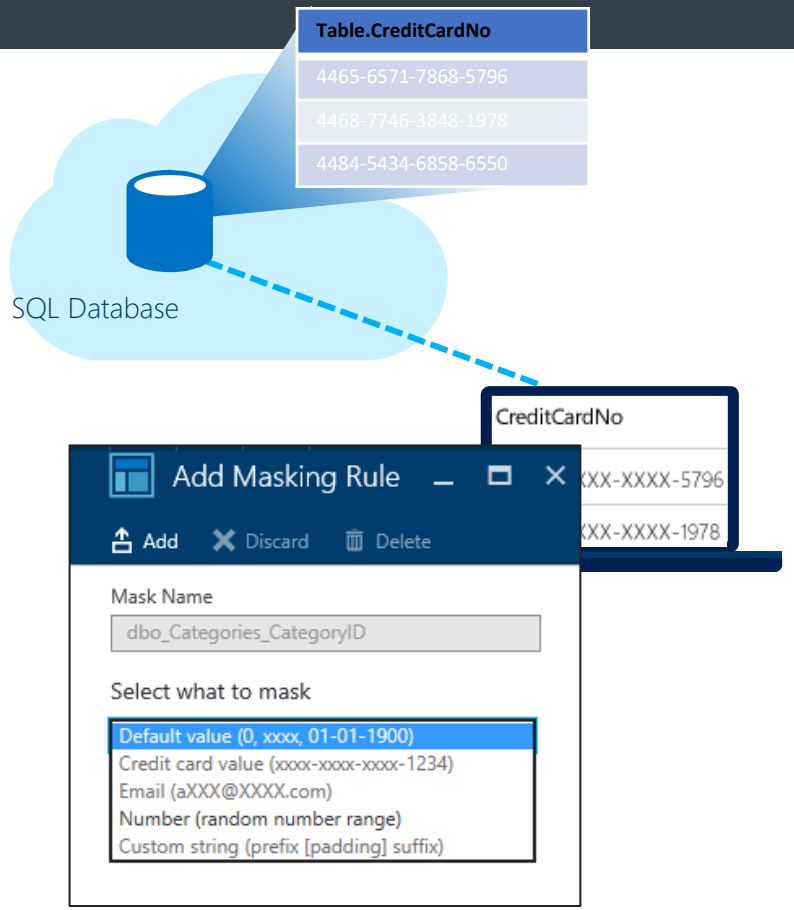


Image source: https://docs.microsoft.com/en-us/azure/sql-database/sql-database-elastic-tools-multi-tenant-row-level-security

Dynamic Data Masking

- Mascheramento
  - Real-time
  - Diversi tipi di maschere
  - Mascheratura parziale
- Basato su regole/permessi
  - A livello di colonna
  - Permesso di «unmask»
- Configurazione Azure nel portale



Funzioni Dynamic Data Masking

- Default
  - Dipendente dal tipo ‘X’, 0, 01.01.1900 00:00:00.0000000
- Email
  - aXXX@XXXX.com
- Random
  - Intervallo di interi
- Stringa Custom
  - Prefix length, [padding char], suffix length

Permessi Dynamic Data Masking

- CRATE e ALTER tabella
- ALTER ANY MASK (con ALTER per la tabella)
- UNMASK
  - Solo a livello di database < SQL Server 2022
- Può comunque aggiornare i dati!

Dynamic Data Masking Gotchas

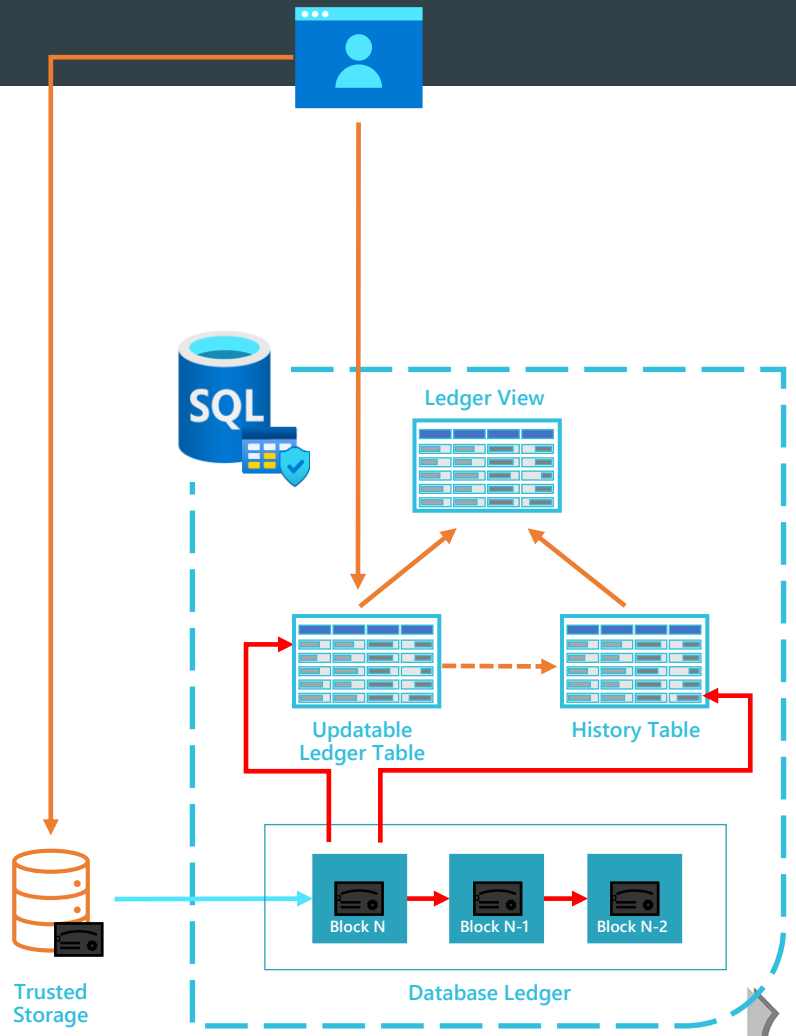
- Attenzione allo spostamento di dati
  - Export/Import
  - SELECT…INTO
  - INSERT…SELECT…FROM
- Tecniche di forza bruta
  - Inferenza di valori (tramite predicati su intervalli)
  - Tabelle con valori di dominio

Limitazione Dynamic Data Masking

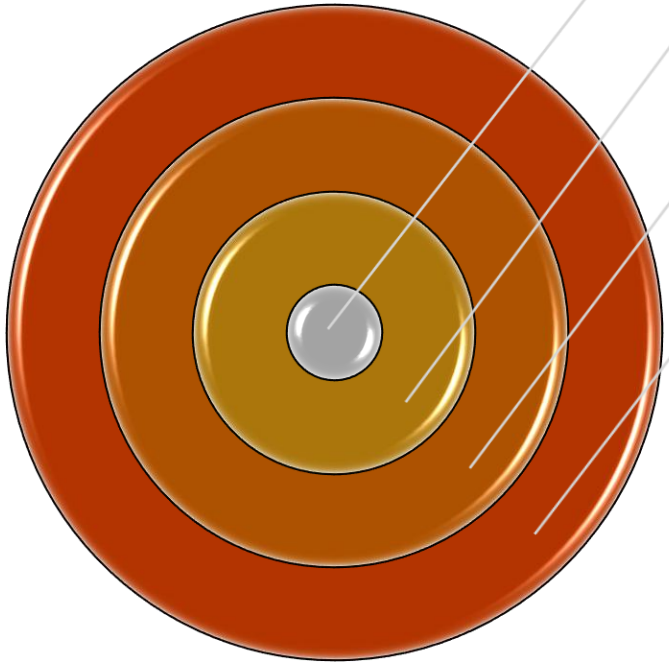
- Tipi colonna non ammessi
  - Colonne crittografate (Always Encrypted)
  - FILESTREAM
  - COLUMN_SET (o «sparse column» che ne fanno parte)
  - Colonne calcolate (però possono referenziare mascherate)
  - Colonne chiave indici FULLTEXT
- READTEXT, UPDATETEXT, WRITETEXT
  - Non funzionano correttamente con UNMASK

Ledger Tables

- **Aggiornabili** permettono insert/update/delete
- Storia righe aggiornate/cancellate preservata in tabelle di storico consultabili tramite «Ledger View»
- Integrità tabelle aggiornabili/storico mantenuta tramite link crittografici del «Database Ledger»
- Sistema può periodicamente generare ricevute digitali da caricare in uno storage affidabile condiviso con il cliente
- Cliente può usare le ricevute per verificare l'integrità del dato
- **Append-Only** permettono solo inserimento
  - Non necessitano di tabelle di storico



Proactive Monitoring



Data Encryption

- Transport Layer Security (in transit)
- Transparent Data Encryption (at rest)
- Cell-Level Encryption (at rest)
- Always Encrypted (at rest and in transit)

Data Access

- Data Masking
- Row-Level Security
- Ledger Tables

Access Control

- Authentication
- Permissions

Proactive monitoring

- Auditing
- Vulnerability Assessment

Cosa tracciare

- Accessi
  - SQL Server Trace (Profiler, deprecato)
  - SQL Server Audit
- Dati modificati (versioni precedenti)
  - Change Data Capture
  - Temporal Databases
- Configurazione e vulnerabilità
  - SQL Assessment API
  - SQL Vulnerability Report
  - Policy Based Management

SQL Server Audit

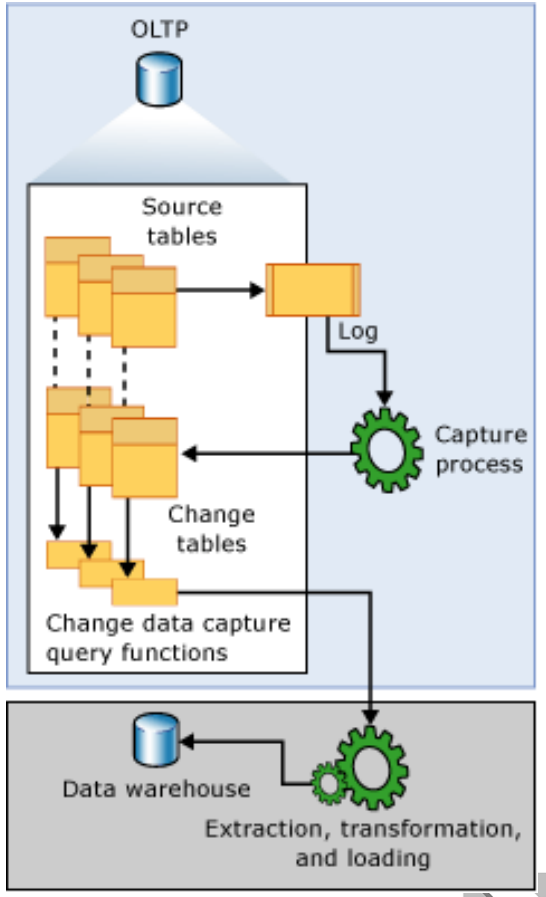
- Definizione gruppi di azioni da tracciare
  - Server
  - Database
- Target
  - File
  - Windows Log
- Disponibile con tutte le edizioni
  - a partire da SQL Server 2016 Service Pack 1
  - Implementazione diversa per Azure SQL Database

Problemi SQL Server Audit

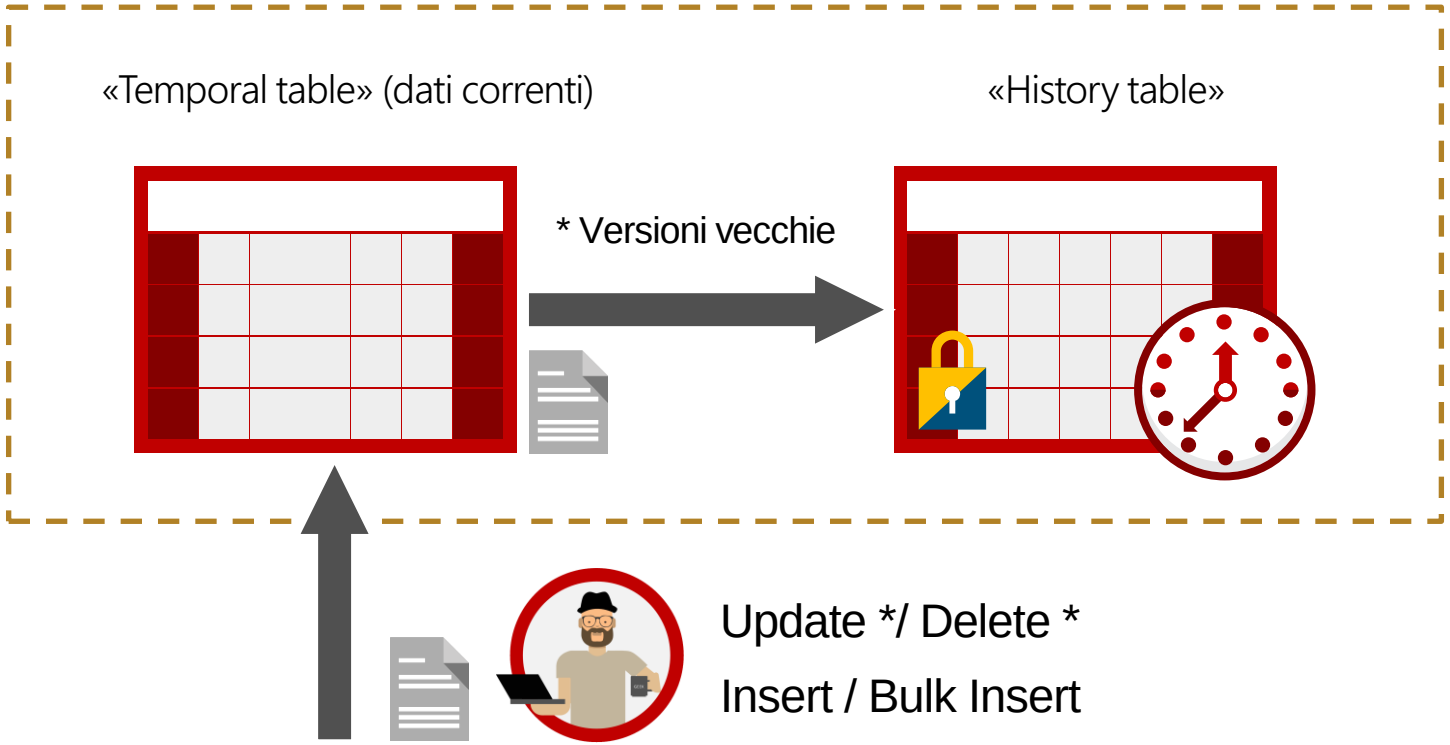
- Volumi eventi generati
- XE Smart Target
  - https://github.com/spaghettidba/XESmartTarget

Change Data Capture

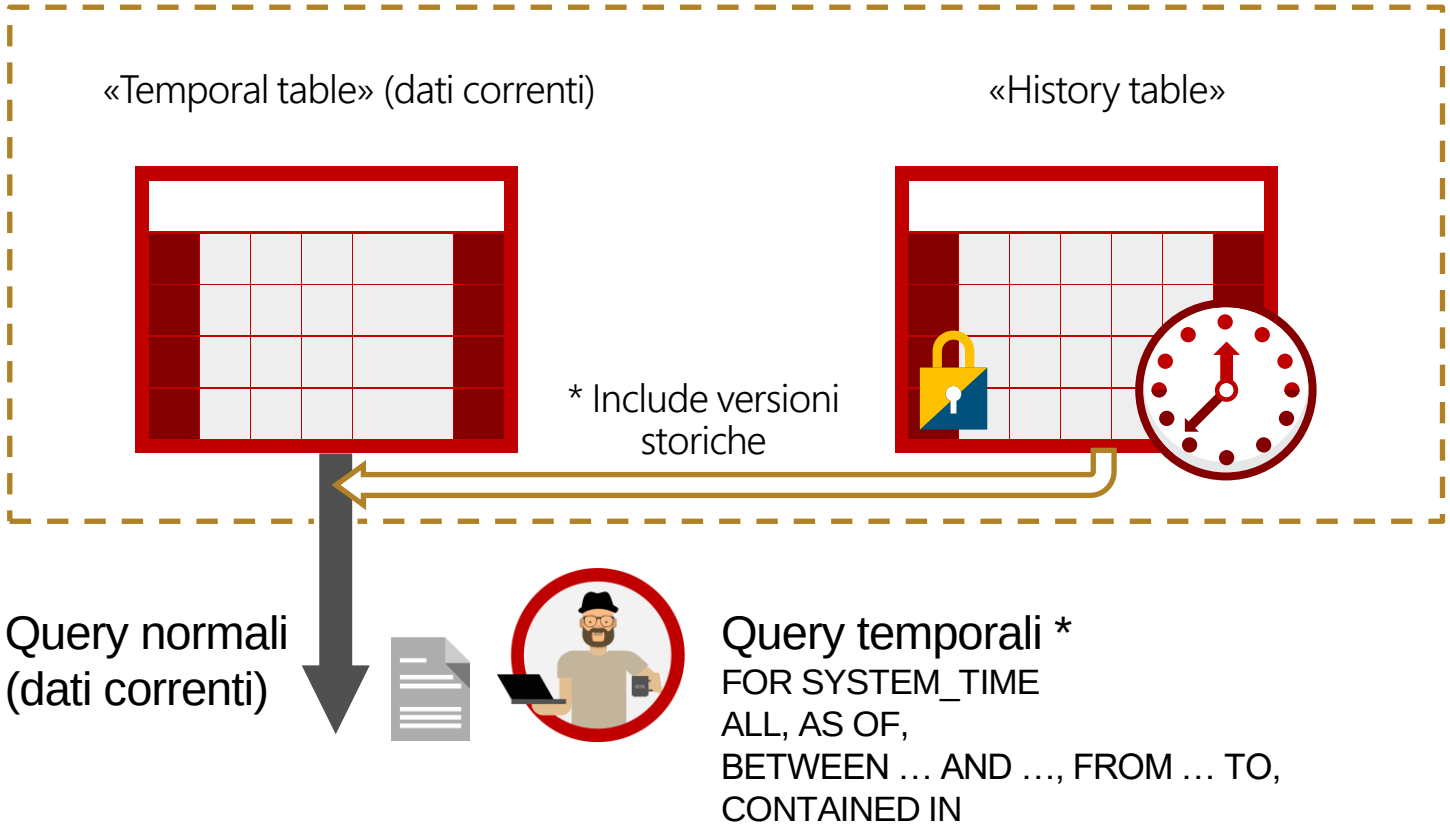
- Soluzione tradizionale Audit modifiche dati?
  - Trigger! Ma…
  - …complessità, prestazioni… ☹
- CDC cattura automaticamente modifiche
  - Pensato principalmente per caricare DWH
  - Genericamente va bene per tenere storico modifiche



Modifiche Database Temporali



Interrogazioni Database Temporali



Audit configurazione e vulnerabilità

- SQL Assesment API
  - SQL Server 2012+
  - ADS, SMO, PowerShell
  - https://learn.microsoft.com/en-us/sql/tools/sql-assessment-api/sql-assessment-api-overview
- SQL Vulnerability Assessment
  - SSMS 19.1è, PowerShell
  - https://learn.microsoft.com/en-us/sql/relational-databases/security/sql-vulnerability-assessment

Policy Based Management

- Infrastruttura per
  - Definizione «policy»
  - Controllo conformità installazione con «policy»
- Serie di «policy» conformi a Best Practice
  - Categoria di policy per sicurezza!
- Enterprise Policy Management Framework
  - http://aka.ms/epmframework

DATA SATURDAYS

GRAZIE

innOva community

altitudo

beanTech IT moves your business

[stesi] Powered by Innovation

CONSORZIO UNIVERSITARIO DI PORDENONE MOLTIPLICATORE DI VALORE